

Checklist Visual — Auditoria Integral do NexOS AI

Base da avaliação: análise estática do código exportado, de schemas, configurações e dependências. O checklist classifica somente o que foi encontrado como evidência técnica. Um item em azul não equivale a funcionamento em produção; ele exige teste controlado e evidência operacional antes de ser promovido a verde.

Referencial de cores

Símbolo	Status	Como interpretar
	Ativo	Controle ou funcionalidade implementada e evidenciada no código, com comportamento coerente na análise estática. Ainda pode exigir validação operacional.
	Implementado, porém não testado em produção	Há rota, serviço ou integração executável, mas não houve teste end-to-end, telemetria de produção ou evidência de permissão ativa.
	Em teste / dry-run / validação incompleta	Há mecanismo de teste, simulação ou implementação em evolução, porém sem aceite funcional completo.
	Não implementado ou não comprovado	Não foi encontrado executor ou evidência técnica suficiente para declarar a capacidade entregue.
	Reprovado	Há falha crítica de segurança, privacidade, confiabilidade ou operação que bloqueia o uso seguro da capacidade.

●	Necessita ajuste ou atualização	A base existe, mas faltam controles, escala, governança, qualidade, teste ou integração para que seja considerada pronta.
---	--	---

Regra de leitura: a cor representa o estado atual da evidência disponível, e não a intenção de produto. A mesma área pode ter itens verdes e itens vermelhos; por exemplo, o NexOS pode gerar um plano de campanha, mas ainda não executá-lo com segurança na Meta Ads.

1. Segurança, identidade, dados e SOC 2 readiness

Status	Tópico auditado	Evidência e veredito
✓	Hash de senhas	Uso de <code>bcrypt</code> com custo 12 para hash e verificação de senha.
✓	JWT com expiração configurável	Access e refresh tokens possuem tempos de expiração no serviço de autenticação.
✓	Rate limit geral, de login e de IA	O servidor aplica limitadores globais e específicos para autenticação e chamadas de IA.
✓	Cabeçalhos de segurança e limite de payload	Uso de <code>helmet</code> , parsing limitado e logging HTTP estruturado na configuração do servidor.
✓	Validação de credenciais de integração	A rota de integração testa credenciais em provedores antes de marcar a conexão como ativa, quando o provedor suporta validação.
●	Isolamento lógico por workspace	Rotas e dados usam <code>workspaceId</code> ; precisa de teste adversarial entre tenants para comprovar isolamento real.
●	Dry-run para agentes	Há modo de simulação que impede chamadas reais de IA;

		deve ser validado como gate efetivo de ambiente.
●	RLS de banco de dados	Não foi encontrada evidência de <code>ENABLE ROW LEVEL SECURITY</code> ou <code>CREATE POLICY</code> nas migrações auditadas.
●	Gestão de sessões por dispositivo	Não foi encontrada evidência de inventário de dispositivo, logout global, revogação persistente ou rotação de refresh token.
●	Credenciais versionadas no repositório	Foi identificada credencial de serviço e token de webhook em arquivo de configuração. Exige rotação e limpeza do histórico Git.
●	Tokens de integrações em texto	Access/refresh tokens de terceiros são persistidos em campos de texto, sem evidência de envelope encryption ou KMS.
●	Assistente público orientando colar segredos	O endpoint público de wizard de integrações aceita conteúdo e imagem sem autenticação e incentiva compartilhamento de tokens.
●	CORS fail-open	Sem allowlist configurada, a configuração de produção pode aceitar qualquer origem.
●	Eventos server-side sem autenticação/assinatura	Endpoint de tracking aceita <code>workspaceId</code> diretamente, com risco de injeção de eventos e corrupção de métricas.
●	Sessões em <code>localStorage</code>	Access e refresh tokens no navegador expõem sessões a exfiltração em caso de XSS.
●	Dependências vulneráveis	A auditoria de dependências reportou 38 vulnerabilidades , incluindo 22 altas .
●	Redação de logs	Apenas alguns headers são mascarados; faltam redaction

		profunda, allowlist de campos e testes de não vazamento de PII/tokens.
●	OAuth robusto	Há state JWT com expiração, mas faltam PKCE onde aplicável, state opaco server-side, rotação de chaves e criptografia de token.
●	Prontidão SOC 2	Não foram comprovadas políticas, evidências de acesso, CI/CD controlado, DR, backup testado, incident response, SLO e gestão de terceiros.

2. Arquitetura, multi-tenancy e qualidade de features

Status	Tópico auditado	Evidência e veredito
✓	Backoffice por workspace	O modelo de dados e diversas rotas contextualizam ações por <code>workspaceId</code> .
✓	Auditoria de ações de agente	Há tabelas e escrita de logs para execuções, tokens, custo, provider, modelo, estado e duração.
●	Integrações por workspace	A plataforma persiste integrações de redes, mídia, mensageria e outros provedores por workspace.
●	Várias contas da mesma rede no mesmo workspace	A rota auditada faz upsert por <code>(workspaceId, provider)</code> ; adicionar outra conta tende a substituir a existente.
●	Seleção de conta social por campanha/funil	Não foi encontrado modelo completo de conta social/anúncio independente com seleção por campanha, conteúdo e fluxo.

●	Qualidade de features em produção	Não há evidência suficiente de cobertura E2E, métricas de adoção, SLO, testes de regressão, canary release ou observabilidade de UX.
●	Isolamento multi-tenant no banco	O isolamento na aplicação não substitui RLS e testes cross-tenant.
●	Controle de mudanças	Não foram comprovadas políticas de PR, proteção de branch, revisão obrigatória, CI de segurança ou rollback auditável.

3. Agentes, memória, persistência e eficiência de tokens

Status	Tópico auditado	Evidência e veredito
✓	Contexto estratégico de agentes	Runner injeta contexto de campanha, perfil psicológico, fase, tempo, clarificações e bibliotecas por papel.
✓	Checkpoints e aprovação	Campanhas e agentes persistem estados e checkpoints para estratégia, criativo, landing page, budget e execução.
✓	Logs de tokens, custo, provider e duração	Execuções armazenam tokens usados, custo estimado, modelo, provider e status.
✓	Idempotência de crédito em campanhas	O débito de créditos usa chave idempotente e transação para muitos fluxos com campanha.
✓	Fallback entre provedores LLM	Router alterna Anthropic, OpenAI e Gemini conforme tipo de tarefa e registra fallback.
●	Memória de campanha	Há contexto/memória e agente de compressão no inventário;

		não foi validada a qualidade de recuperação em execução real.
●	Teste de fallback de provedor	Há mecanismo de teste para forçar fallback; falta evidência de teste de caos e aceite operacional.
●	SLA comprovado para deep thinking acima de 20 minutos	Não foi demonstrado teste de 20–30+ minutos com reinício de worker, retomada e uma única cobrança.
●	Recuperação universal após crash	Não foi encontrada máquina de estado durável por passo, aplicável universalmente a todos os agentes.
●	Proteção contra repetição em agentes sem campanha	Vídeo, legados e fluxos sem <code>campaignId</code> podem passar pelo caminho sem chave estável de idempotência.
●	Orçamento total de tokens	Há contabilização por chamada, mas não orçamento por campanha/workspace, alerta de anomalia, cache semântico ou deduplicação completa de contexto.
●	Prompt engineering para eficiência	Camadas estáticas extensas são injetadas em muitas chamadas; pipeline mode reduz apenas parte do contexto.
●	Qualidade mínima no fallback	O router troca o provedor em erro, mas não foi encontrada uma rubrica de qualidade ou política para degradar/reprovar resposta de fallback.

4. APIs, logs, automação e resiliência

Status	Tópico auditado	Evidência e veredito
--------	-----------------	----------------------

✓	Rotas autenticadas para operações principais	Fluxos de campanha, execução e diversas operações usam middleware de autenticação.
✓	Workflow de lançamento com gates	A execução exige integração, aprovação de conteúdo e validações antes de enfileirar a fase.
✓	Eventos em tempo real	Há emissão de eventos para início, pensamento, conclusão e checkpoints de agentes.
✓	Retry e backoff em sequências de DM	Falhas de envio registram erro, incrementam retry e usam backoff progressivo.
●	Webhooks de Meta/WhatsApp	Há processamento de eventos e chamadas aos provedores; falta validar assinatura, App Review, escopos e telemetria em produção.
●	Testes de provedor/fallback	Existem controles de teste e dry-run, mas não foi fornecida suíte de integração executada.
●	Circuit breaker compartilhado	Não foi encontrada implementação central de circuit breaker por provedor/integrador.
●	Dead-letter queue e replay operacional	Não foi comprovada fila de falhas com replay, triagem e limite de tentativas por tipo de ação externa.
●	Logs de API prontos para auditoria	Há estruturas de log, mas faltam retenção, imutabilidade, alertas, correlação completa e proteção de dados.
●	Health checks, SLO e operação de fornecedores	Não foram comprovados health checks centralizados, limites de quota, monitoramento de disponibilidade ou runbooks por API.

5. Social media, comentário, DM, comunidade e concorrência

Status	Tópico auditado	Evidência e veredito
✓	Plano semanal de presença social	Há serviço para gerar e persistir plano social por plataforma.
✓	Agendamento e publicação social	Há serviços para processar posts aprovados e publicar conteúdo devido.
✓	Publicação de carrossel no Instagram	O publisher cria itens de carrossel, container e publicação.
✓	Métricas sociais básicas	Serviços coletam métricas como alcance, impressões, curtidas, comentários, compartilhamentos, saves e views quando a plataforma as fornece.
✓	Moderação de comentários	Há classificação, resposta, curtir, ocultar e exclusão para comentários de Instagram/Facebook.
✓	DM por palavra-chave e sequência	O webhook dispara sequência, deduplica o destinatário e envia mensagens pela Graph API.
✓	WhatsApp por Cloud API	Há envio de texto/template, dispatch, webhook e resposta por agente.
●	Autopost de conteúdo aprovado	A integração de publicação existe, mas ainda não foi demonstrada contra contas reais em cada plataforma.
●	Geração de mídia, storyboard e vídeo	Há pipeline de geração/aprovação; qualidade visual e fluxo completo precisam de testes reais.
●	Resposta automática a comentários	A implementação é executável, mas requer validação de

		permissões, reputação, limites, App Review e política humana.
●	Resposta a DMs	A execução existe, mas está centrada em keyword/fluxo, não em conversa universal multi-turn.
●	Monitoramento contínuo de perfis concorrentes	Há análise de concorrência como insight, mas não monitoramento operacional contínuo de contas concorrentes.
●	Criação e gestão de grupos WhatsApp	Tipos de dispatch incluem grupo, mas não foi encontrado executor para criar, gerir membros ou administrar grupos.
●	Criação e gestão de grupos Telegram	Há referências em sequências, mas não integração de bot/grupo completa comprovada.
●	Comentários promocionais automáticos em concorrentes	Não foi encontrado executor e a funcionalidade não deve ser tratada como requisito seguro: pode configurar spam, astroturfing ou comportamento enganoso.
●	Governança de moderação	Faltam aprovação humana por risco, limiar de confiança, proteção contra prompt injection em comentário, limites por conta e política de escalonamento.
●	Privacidade de DMs	O logger registra texto e identificadores de DM; deve haver minimização, redaction e retenção definida.

6. Storytelling, criativos, vídeos, carrosséis e Masterplan

Status	Tópico auditado	Evidência e veredito
✓	Agentes de copy, criativo e vídeo	Há papéis específicos para copywriter, creative director, video strategy, VSL e conceitos criativos.
✓	Contexto de avatar e etapa de funil	O runner injeta perfil psicológico, estado da fase, memória e contexto temporal nos prompts.
✓	Diretrizes anti-alucinação e autocritique	Prompts contêm regras de coerência, adequação ética e revisão antes de resposta.
●	Storyboard e mídia de post	Há criação, aprovação de imagem e confirmação de vídeo no serviço social.
●	Carrossel publicável	O transporte de múltiplas imagens está implementado; a qualidade narrativa ainda não foi aceita com exemplos reais.
●	Avaliador determinístico de storytelling	Não foi encontrada regra que valide automaticamente abertura, tensão, progressão, prova, CTA, continuidade de slides e aderência ao Masterplan.
●	Validador de 5–10 imagens	Não foi comprovado um gate que imponha quantidade, lógica entre imagens e coerência visual antes de publicar.
●	Benchmark de qualidade criativa	Falta rubrica mensurável, avaliação por marca, testes A/B e feedback de performance conectado ao gerador.

7. Funis, geração de demanda, leads e landing pages

Status	Tópico auditado	Evidência e veredito
✓	Agentes de funil e vendas contínuas	Há agentes que estruturam funil, sequência, consciência, objeções, vendas e distribuição.
✓	Geração de sequências e dispatches	O bridge transforma partes da campanha em itens de sequência para canais disponíveis.
✓	Captura de leads em rotas específicas	Há rotas de lead capture/waitlist e notificações.
●	Sequências WhatsApp/e-mail/Telegram	Há estrutura e itens de sequência; cada canal exige teste de integração e consentimento.
●	Landing page real publicada	O agente gera JSON de copy/estrutura; não há builder, renderer, domínio, deploy, pixel ou publicação comprovados.
●	CRM e lifecycle completos	Não foi comprovado pipeline de CRM, lead scoring, ownership comercial, SLA, receita fechada e atribuição completa.
●	Atribuição de ponta a ponta	Não há evidência de modelo de atribuição ligando tráfego, lead, atendimento, venda e LTV de forma reconciliada.
●	Consentimento e base legal de funil	A automação de mensageria e captura precisa de registro de opt-in, finalidade, preferência, descadastro e retenção.

8. Meta Ads, públicos, lookalikes e campanhas de alta performance

Status	Tópico auditado	Evidência e veredito
--------	-----------------	----------------------

✓	Agente de media buyer	Gera estrutura de campanha, orçamento, públicos, criativos, regras de escala e corte em JSON.
✓	Agente de targeting	Produz hipóteses de interesses, comportamentos, segmentos e públicos planejados.
✓	OAuth Meta Ads em tese	Há fluxo OAuth e escopos <code>ads_management</code> e <code>ads_read</code> .
✓	Gate interno de execução	O lançamento exige integração e aprovação antes de mudar o estado interno e criar sequências.
●	Credenciais de Meta Ads por workspace	O código prevê a integração, mas não foi validado contra uma conta de anúncios real.
●	Criar Campaign via Marketing API	Não foram encontradas chamadas executáveis para criação de campaign.
●	Criar Ad Set, Creative e Ad	Não foram encontradas chamadas executáveis para esses recursos.
●	Programar orçamento, placement, objetivo, conversão e tracking	O sistema planeja parâmetros; não foi encontrado executor que os envie à Meta.
●	Criar custom audiences e lookalikes	Há referências em prompts, sem executor para endpoints de audiência ou LAL.
●	Ler Insights de mídia paga	Não foi encontrado importador de Insights de campaign/ad set/ad.
●	Otimizar orçamento, pausar, escalar ou duplicar campanha	Não foi encontrado executor de ações de otimização na Marketing API.
●	Reconciliar estado interno com estado Meta	<code>live</code> é estado interno do NexOS; não há reconciliação com IDs e status externos de mídia paga.

●	Segurança operacional de Ads	A futura implementação exige draft versionado, validação, aprovação humana, idempotência, IDs externos, rollback e trilha de auditoria.
●	Uso responsável de públicos	Lookalikes e audiências devem usar fontes consentidas, finalidade registrada, mínimo de dados e revisão de política/plataforma.

9. Resiliência, disponibilidade e auditoria independente

Status	Tópico auditado	Evidência e veredito
✓	Fallback de LLM	Há cadeia de provedores por tipo de tarefa e registro da utilização de fallback.
✓	Checkpoints de campanha	Existem checkpoints e logs de execução para parte relevante do fluxo.
●	Heartbeat de worker	Há heartbeat de estratégia; deve ser provado em carga e sob reinício.
●	Backup/restore testado	Não foi encontrado evidência versionada de RPO/RTO, backup e restauração testada.
●	Plano de disaster recovery	Não foi comprovado runbook de DR, failover ou simulação de incidente.
●	Gestão de incidentes	Não foram encontradas evidências de playbook, severidade, comunicação, postmortem e treinamento.
●	Pentest e validação externa	Não foram fornecidos resultados de pentest, DAST, SAST ou revisão independente.
●	Evidências para due diligence	São necessários inventário de ativos, políticas, matriz de

		acesso, evidências CI/CD, logs protegidos, revisão de fornecedor, risco, backup e testes de controle.
--	--	---

10. Ordem recomendada de aprovação e implementação

Prioridade	Bloco	Resultado esperado
P0 — bloquear risco	Rotação de segredos, limpeza do Git, CORS fechado, proteção de endpoints públicos, remoção de tokens do <code>localStorage</code> , SCA de dependências.	Reduzir risco crítico antes de expandir automações.
P1 — fundação	KMS/envelope encryption, RLS, sessões seguras, redaction de logs, multi-account, CI e observabilidade.	Tornar o sistema apto a operar contas e dados com isolamento.
P2 — confiabilidade	Jobs duráveis, checkpoints universais, replay, budgets de tokens, cache, memória versionada e SLO.	Evitar perda de contexto, repetição, custo excessivo e queda em deep thinking.
P3 — execução de produto	Landing pages, quality gate de criativos, CRM/atribuição, social multi-account, DM/handoff e comunidade.	Converter planejamento em operação mensurável e controlada.
P4 — Meta Ads	Draft→approval→executor→reconciliation→Insights→otimização limitada.	Criar campanhas de tráfego de forma segura, idempotente e auditável.

Referências de evidência

Código	Fonte
E1	<code>artifacts/api-server/src/app.ts</code> — segurança HTTP, CORS e rate limits.

E2	<code>artifacts/api-server/src/modules/auth/*</code> e <code>artifacts/app/src/lib/auth.tsx</code> — autenticação e sessão.
E3	<code>lib/db/src/schema/*</code> e rotas OAuth/integrações — workspace, tokens e isolamento.
E4	<code>artifacts/api-server/src/modules/agents/*</code> e <code>ai-gateway/llm-router.ts</code> — agentes, memória, custo e fallback.
E5	<code>artifacts/api-server/src/modules/social*</code> , <code>social-presence</code> , <code>social-moderation</code> e <code>whatsapp</code> — publicação, DM, comentários e mensageria.
E6	<code>artifacts/api-server/src/modules/orchestration/*</code> , <code>media-buyer.agent.ts</code> , <code>targeting*</code> e busca estática de Marketing API — lançamento e Meta Ads.
E7	<code>pnpm audit --prod</code> executado contra a cópia fornecida — vulnerabilidades de produção.
E8	AICPA, Trust Services Criteria — enquadramento de prontidão SOC 2.